Terraform and Sentinel

Technical report | Michael Turvey | L00068839 | 7 November 2026

Implementation and results

The framework evaluates Terraform plans in HCP Terraform using one hard mandatory Sentinel policy. A six-resource AWS example includes a VPC, private subnet, security group, restricted SSH rule, EC2 instance and encrypted EBS volume. No resources were deployed. HCP runs accepted compliant plans and rejected unencrypted storage, an out-of-Ireland storage zone, an unapproved instance type, optional IMDSv2, a public IP, unrestricted SSH and a loose provider version constraint. Four local mock cases verified module acceptance, module source and version rejection, and provider source rejection.

Digital sovereignty

Ireland availability-zone checks provide a repeatable location control for EC2 and EBS, but do not establish full sovereignty. Backups, replication, administrative access and control-plane data need separate controls. This implementation does not enforce backup or replication destinations, determine administrator location, or establish Irish residency for HCP state, logs or GitHub data. Legal and contractual jurisdiction requires separate assessment.

Supply chain and enforcement limits

The AWS provider source and exact 6.55.0 constraint are allowlisted. The committed provider lock file records dependency hashes. Module checks allowlist the VPC module at version 6.0.1; the configuration itself has no module calls, so module enforcement is demonstrated with mocks. Source allowlisting and version pinning do not prove code integrity or absence of vulnerabilities. Sentinel executes after initialisation and planning, so it cannot prevent malicious provider code executing earlier.

Coverage and recommendations

The network rule inspects standalone ingress resources only. Inline and legacy security group rules, network ACLs and other network paths are outside its coverage. Additional inline EC2 EBS devices and runtime drift are also outside scope. Extend resource coverage and negative tests, inspect backup and replication settings, and add runtime monitoring. Review dependency provenance and vulnerabilities, use controlled runners, and automate synchronisation of reviewed policy code with HCP. Retest when provider schemas or approved dependencies change. Dummy credentials and a placeholder AMI make this a plan-only demonstration, not deployment-ready infrastructure.

Evidence and AI declaration

The repository contains configuration, policies, mock tests, execution logs and an HCP saved-plan reference, with a readable plan copy. Passing and failing HCP screenshots support the recorded results. Substantial OpenAI ChatGPT/Codex assistance generated code, commands and documentation and supported troubleshooting. Michael configured the tools, executed tests and collected evidence. Exact model version was not recorded. AI-USAGE.md lists representative prompts and contributions; the conversation is the full prompt record.